

La bitácora desordenada de Viña Valle Escondido

PF1495 · Hacking Ético en Aplicativos Web
Módulo 2 · MA03807 · Introducción al hacking ético

MODALIDAD

Individual.

APRENDIZAJE ESPERADO 4

Analizar aspectos metodológicos de hacking ético, distinguiendo fases, herramientas y marcos metodológicos acorde a las buenas prácticas y estándares de la industria

CRITERIOS DE EVALUACIÓN

- 4.1 Reconoce las fases del hacking ético para el testeo de la seguridad de un sistema acorde a las buenas prácticas de la industria.
- 4.2 Ejemplifica cada fase del ciclo de vida de un ataque mediante casos y ejemplos prácticos acorde las buenas prácticas de la industria.
- 4.3 Describe aspectos fundamentales de las metodologías de hacking ético acorde las buenas prácticas de la industria

Contexto

Viña Valle Escondido (empresa ficticia) autorizó por escrito una prueba de su tienda web. La bitácora del equipo quedó desordenada:

- a) Se entrega el informe con los hallazgos priorizados y las recomendaciones.
- b) Con autorización, se usa Nmap para listar los servicios y versiones que responden en el servidor de la tienda.
- c) Se busca información pública: dominio, tecnologías mencionadas en avisos de empleo y correos publicados.
- d) Se demuestra que el formulario de cupones permite ver productos ocultos, con una evidencia mínima.
- e) Se evalúa qué datos alcanza ese acceso, sin salir del alcance, y se eliminan las cuentas de prueba creadas.
- f) Con un proxy como OWASP ZAP, se listan las rutas y los formularios del sitio.

Qué tienes que hacer

- 1. Fases (criterio 4.1).** Ordena la bitácora en las cinco fases del hacking ético (reconocimiento, enumeración, explotación, post-explotación e informe) y explica en una línea el objetivo de cada fase.

- 2. Ciclo de vida de un ataque (criterio 4.2).** Para cada fase, da un ejemplo de lo que haría un atacante real y en qué se diferencia lo que hace el hacker ético con autorización.
- 3. Practica el reconocimiento (criterio 4.2).** Instala OWASP Juice Shop en tu propio equipo y recórrelo como lo haría un cliente: anota cinco datos útiles para una prueba (páginas, formularios, tecnologías visibles). Solo en tu laboratorio, nunca en un sitio real.
- 4. Metodologías (criterio 4.3).** Explica qué aporta la guía de pruebas de OWASP y qué aporta PTES (Penetration Testing Execution Standard), y propón cómo repartir un plazo de 10 días hábiles entre las fases, priorizando lo crítico.

Entrega

Sube a esta Tarea un documento PDF de 1 a 2 páginas con la bitácora ordenada, los ejemplos por fase, tus cinco datos del laboratorio con una captura y la propuesta de metodología y plazos.